Information Security Policy

PrairieTrust Healthcare Services | Fictional organization | Training simulation

Document ID	PTHS-ISP-001
Version	0.1 — Draft
Status	Draft — Pending Executive Approval (simulated)
Owner	Information Security Manager (fictional role)
Prepared by	Junior GRC Analyst — Training Simulation
Approval authority	Executive Leadership (fictional role)
Approval date	Not approved / Not applicable
Effective date	Not effective / Not applicable
Review frequency	At least annually and after significant changes
Classification	Internal — Simulated

TRAINING DISCLAIMER: This document is a fictional policy-development exercise. It is not approved, implemented, or audited at a real healthcare organization.

1.0 Purpose

This policy establishes requirements for protecting PrairieTrust Healthcare Services information and information systems from unauthorized access, disclosure, alteration, destruction, and disruption. It supports confidentiality, integrity, availability, risk management, and applicable legal, regulatory, and contractual obligations.

2.0 Scope

This policy applies to employees, contractors, and approved third parties who access, process, store, or transmit organizational information. It covers information, systems, devices, applications, networks, cloud services, and remote-access environments used for organizational business, regardless of location.

3.0 Policy Statement

Covered personnel must protect organizational information and systems, comply with approved security requirements, and promptly report suspected incidents through designated channels. Access must be authorized based on legitimate business need and least privilege.

4.0 Roles and Responsibilities

Executive Leadership: Approves this policy and material revisions, provides oversight, and supports the security program.

Information Security Manager: Owns and maintains the policy, coordinates reviews, oversees policy governance, and escalates significant concerns.

IT / Identity and Access Management (IAM): Implements assigned technical controls, administers access, maintains relevant configurations, and remediates technical deficiencies.

Governance, Risk, and Compliance (GRC): Coordinates assessments, evaluates control evidence, documents findings, tracks remediation, and reports compliance concerns.

Managers and Human Resources: Perform the authorization and notification duties assigned under the access lifecycle process.

Employees, Contractors, and Approved Third Parties: Follow requirements, safeguard information, complete assigned training, and report suspected incidents.

5.0 Information Security Requirements

5.1 Access Control

Access to organizational systems must be authorized based on business need and least privilege.

Joiners: The designated manager must approve access before IT/IAM provisions permissions. IT/IAM must grant only access required for approved job responsibilities.

Movers: The responsible manager or Human Resources must notify IT/IAM through the approved access-change process. IT/IAM must review and remove access no longer required by the effective role-change date.

Leavers: Human Resources must notify IT/IAM through the approved offboarding process. IT/IAM must disable organizational access no later than the effective separation time, or earlier when authorized.

Provisioning, changes, and revocations must be documented and retained under applicable access-management requirements.

5.2 Authentication Security

Multifactor authentication (MFA) must be enforced for organizational accounts used by employees and contractors, including accounts with privileged access, in accordance with approved authentication standards.

MFA must be enforced on applicable access paths through technical configuration and must not depend solely on voluntary user enrollment. Exceptions must follow Section 6.0.

5.3 Information Protection

Confidential information must be stored, accessed, processed, and transmitted using approved systems and security methods. Personnel must not copy confidential information to unauthorized personal storage or removable media. Information handling must reflect sensitivity and applicable protection requirements.

5.4 Endpoint and System Security

Organizational endpoints and systems must follow approved security configuration and maintenance requirements. Responsible teams must apply relevant security updates, endpoint protection, and risk-appropriate safeguards. Required controls must not be bypassed without authorization under Section 6.0.

5.5 Security Incident Reporting

Covered personnel must promptly report suspected phishing, suspicious communications, unauthorized access, and potential security incidents through designated reporting channels. Reports must be handled under approved incident response procedures.

5.6 Security Awareness and Training

Covered personnel must complete required security awareness training. Training must address relevant risks including phishing, credential protection, sensitive information handling, and incident reporting. Completion and required acknowledgments must be retained according to organizational requirements.

6.0 Policy Exceptions and Enforcement

Exceptions must be documented, risk-assessed, reviewed by the Information Security function, and approved by the designated risk acceptance authority before implementation.

Requests must identify justification, affected systems and information, risks, compensating controls, an owner, and an expiration or review date. Approved exceptions must be monitored and periodically reassessed.

Undocumented, unauthorized, or indefinite exceptions are prohibited. Exceptions must not bypass legal or regulatory obligations. Violations may lead to corrective action under applicable procedures.

7.0 Monitoring and Compliance

Compliance with security policies, standards, and procedures must be periodically assessed using activities appropriate to organizational risks and requirements.

Control deficiencies must be documented, risk-evaluated, assigned owners, and tracked through remediation. Control owners must supply relevant evidence of corrective actions.

GRC must review supporting evidence and document validation before recommending formal finding closure under the approved process. Completion of a remediation ticket alone is insufficient. Significant deficiencies must be reported to appropriate management.

8.0 Policy Review and Revision History

8.1 Review Requirements

This policy must be reviewed at least annually and following significant operational, technology, cybersecurity risk, legal, regulatory, or contractual changes. Examples include new cloud services, expanded remote work, and significant cybersecurity incidents.

The Information Security Manager coordinates reviews and proposed revisions. Material changes require formal approval by Executive Leadership or the designated approval authority before implementation.

8.2 Revision Management

Following actual approval, the Information Security Manager must update the version number, revision history, approval date, and effective date. Approved revisions must be published and communicated to affected personnel.

Superseded versions, approval records, relevant training records, and required acknowledgments must be retained under applicable document-retention requirements.

8.3 Revision History

Version 0.1 — Initial consolidated training draft; QF-01 through QF-04 simulated quality corrections incorporated; status: DRAFT, NOT APPROVED. No subsequent version has been issued.

9.0 Document Approval

Approval status: Pending executive approval (fictional workflow only). Approver: None. Approval date: None. Effective date: None. This training artifact does not claim real authorization, operational implementation, or control effectiveness.